Software Quality Assurance (SQA) – 5th Week Project Task

Name: Dariya Hashmi -- DHC (2403)

Project Title: Security Testing & Vulnerability Analysis

Objective:

Introduce basic web application security vulnerabilities and demonstrate how QA engineers test them using OWASP ZAP on "The Internet" demo website. Focus is on automated vulnerability scanning, input validation, authentication testing, and session management.

Tools Used :

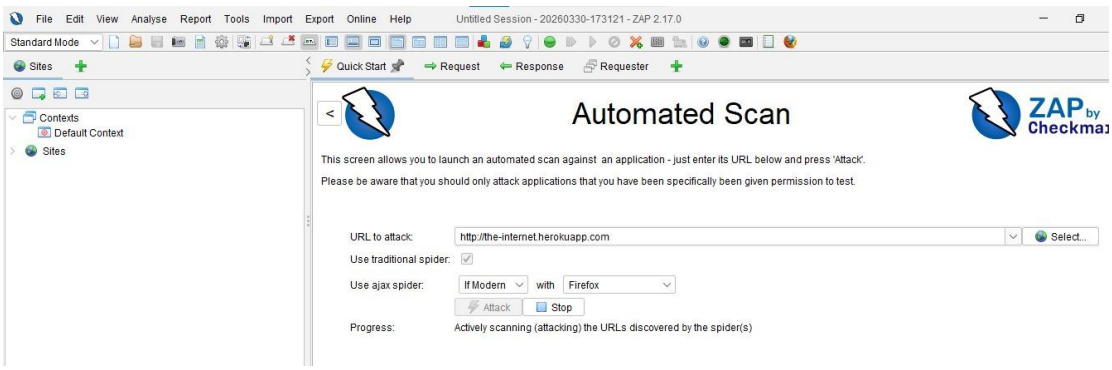
- OWASP ZAP (Automated Scan)
- Demo website: https://the-internet.herokuapp.com
- Browser (Chrome/Edge)

Tasks / Steps Performed :

1. Launch ZAP → Quick Start → Automated Scan
2. Enter target URL → Attack
3. Run **Spider (site crawling)**
4. Run **Active Scan**
5. Capture Alerts and History

Screenshots :

- Automated Scan Start :



- Spider Progress (~50–70%) :

History Search Alerts Output Spider AJAX Spider Active Scan Insights

New Scan Progress: 0: http://the-int.t.herokuapp.com 100% Current Scans: 0 URLs Found: 320 Nodes Added: 240 Export

URLs Added Nodes Messages

Processed	Method	URI	Flags
	GET	http://klauzinski.com/	Out of Scope
	GET	http://www.gnu.org/licenses/gpl-2.0.html	Out of Scope
	GET	http://jqueryui.com/themeroller/?bgColorActive=ffffff&bgColorContent=ffffff&bgColo...	Out of Scope
	GET	http://the-internet.herokuapp.com/frame_left	
	GET	http://the-internet.herokuapp.com/frame_middle	
	GET	http://the-internet.herokuapp.com/frame_right	
	GET	http://the-internet.herokuapp.com/shifting_content/menu?mode=random	
	GET	http://the-internet.herokuapp.com/shifting_content/menu?pixel_shift=100	
	GET	http://the-internet.herokuapp.com/shifting_content/menu?mode=random&pixel_s...	
	GET	http://the-internet.herokuapp.com/shifting_content/image?mode=random	
	GET	http://the-internet.herokuapp.com/shifting_content/image?pixel_shift=100	
	GET	http://the-internet.herokuapp.com/shifting_content/image?mode=random&pixel_s...	
	GET	http://the-internet.herokuapp.com/shifting_content/image?image_type=simple	
	GET	http://the-internet.herokuapp.com/img/avatar.jpg	
	GET	http://the-internet.herokuapp.com/infinite_scroll/3	
	GET	http://the-internet.herokuapp.com/infinite_scroll/4	

Alerts 2 6 5 5 Main Proxy: localhost:8080 Current Status 0 0 0 0 0 0 0 0 0 0 0

History Search Alerts Output Spider AJAX Spider Active Scan Insights

New Scan Progress: 0: http://the-int.t.herokuapp.com 100% Current Scans: 0 URLs Found: 320 Nodes Added: 240 Export

URLs Added Nodes Messages

Processed	Method	URI	Flags
	GET	http://the-internet.herokuapp.com	Seed
	GET	http://the-internet.herokuapp.com/robots.txt	Seed
	GET	http://the-internet.herokuapp.com/sitemap.xml	Seed
	GET	https://github.com/tourdedave/the-internet	Out of Scope
	GET	http://the-internet.herokuapp.com/abtest	
	GET	http://the-internet.herokuapp.com/add_remove_elements/	
	GET	http://the-internet.herokuapp.com/basic_auth	
	GET	http://the-internet.herokuapp.com/broken_images	
	GET	http://the-internet.herokuapp.com/challenging_dom	
	GET	http://the-internet.herokuapp.com/checkboxes	
	GET	http://the-internet.herokuapp.com/context_menu	
	GET	http://the-internet.herokuapp.com/digest_auth	
	GET	http://the-internet.herokuapp.com/disappearing_elements	
	GET	http://the-internet.herokuapp.com/drag_and_drop	
	GET	http://the-internet.herokuapp.com/dropdown	
	GET	http://the-internet.herokuapp.com/dynamic_content	

- Active Scan Complete (100%)

History Search Alerts Output Spider AJAX Spider Active Scan Insights

New Scan Progress: 0: http://the-int.t.herokuapp.com 100% Current Scans: 0 Num Requests: 8456 New Alerts: 1680 Export

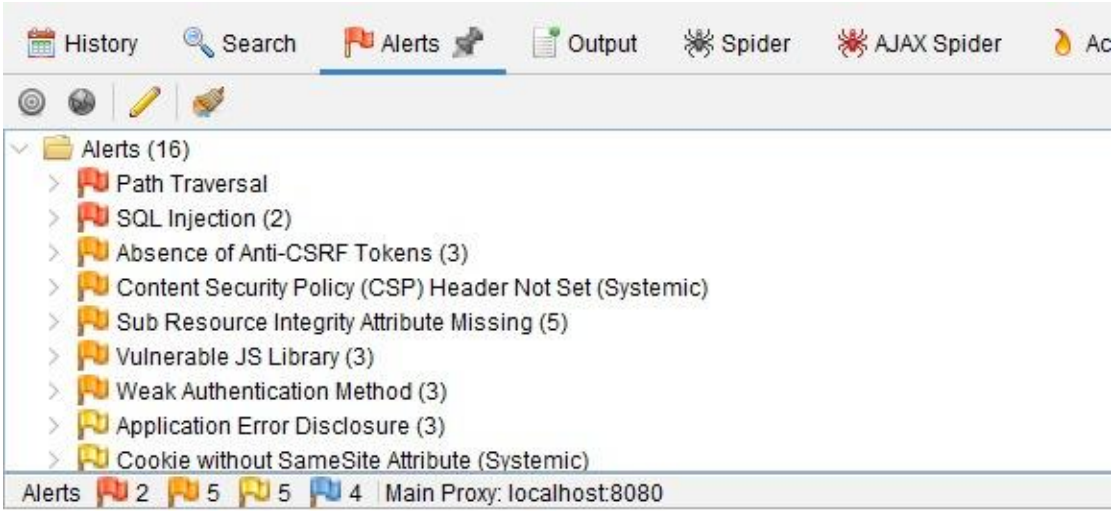
Sent Messages Filtered Messages

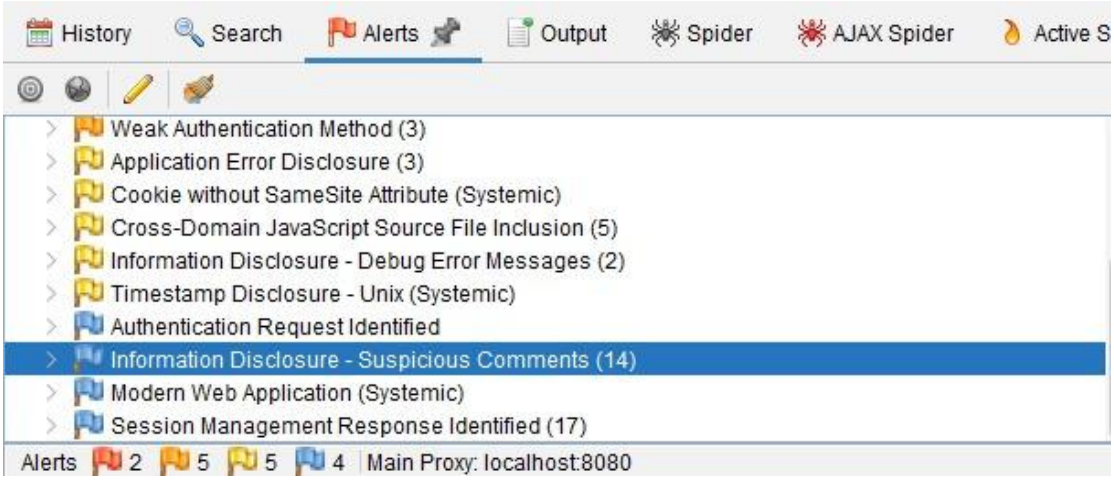
ID	Req. Timestamp	Resp. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body
9,499	3/30/26, 5:57:05 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/img	404	Not Found	253 ms	1,301 bytes	18 bytes
9,500	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/horizontal_slider	200	OK	247 ms	1,304 bytes	2,092 bytes
9,501	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/geolocation	200	OK	254 ms	1,304 bytes	2,360 bytes
9,502	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/hovers	200	OK	263 ms	1,304 bytes	2,378 bytes
9,503	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/frames	200	OK	252 ms	1,304 bytes	1,680 bytes
9,504	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/hjkl.jpg	404	Not Found	283 ms	1,301 bytes	18 bytes
9,505	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/iframe	200	OK	253 ms	1,304 bytes	2,017 bytes
9,506	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/gallery	404	Not Found	252 ms	1,301 bytes	18 bytes
9,507	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/img	404	Not Found	293 ms	1,301 bytes	18 bytes
9,508	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/horizontal_slider	200	OK	245 ms	1,304 bytes	2,092 bytes
9,509	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/geolocation	200	OK	253 ms	1,304 bytes	2,360 bytes
9,510	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/hovers	200	OK	254 ms	1,304 bytes	2,378 bytes
9,511	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/frames	200	OK	244 ms	1,304 bytes	1,680 bytes
9,512	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/hjkl.jpg	404	Not Found	252 ms	1,301 bytes	18 bytes
9,513	3/30/26, 5:57:06 PM	3/30/26, 5:57:06 PM	GET	http://the-internet.herokuapp.com/iframe	200	OK	261 ms	1,304 bytes	2,017 bytes

Findings / Alerts:

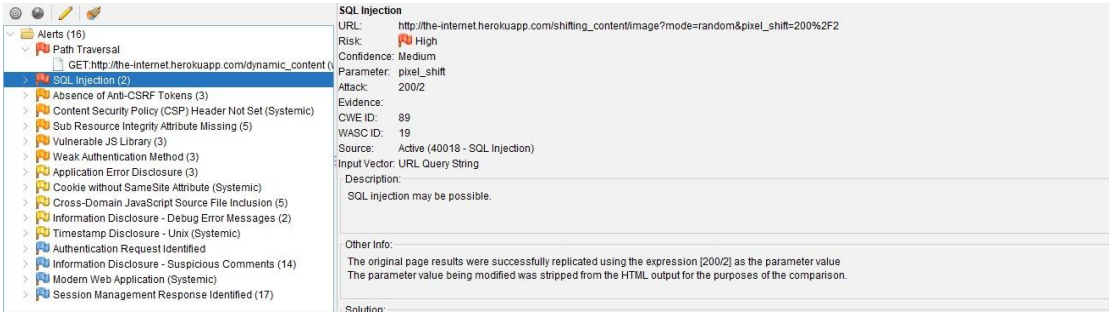
Automated scan detected following vulnerabilities:

- **Alerts Tab Screenshot** → shows all vulnerabilities





- **Individual Vulnerability Screenshot** → shows one example



Other Info:

The original page results were successfully replicated using the expression [200/2] as the parameter value
The parameter value being modified was stripped from the HTML output for the purposes of the comparison.

Solution:

Do not trust client side input, even if there is client side validation in place.
In general, type check all data on the server side.
If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?'

Reference:

https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Alert Tags:

Key	Value
POLICY_SEQUENCE	
OWASP_2021_A03	https://owasp.org/Top10/A03_2021-Injection/
PCI_DSS	https://www.zaproxy.org/docs/desktop/addons/common-library/alerttags/#complian...
CWE-89	https://cwe.mitre.org/data/definitions/89.html
POLICY_QA_CICD	

ider AJAX Spider Active Scan Insights

Absence of Anti-CSRF Tokens

URL: http://the-internet.herokuapp.com/login
Risk: Medium
Confidence: Low
Parameter:
Attack:
Evidence: <form name="login" id="login" action="/authenticate" method="post" >
CWE ID: 352
WASC ID: 9
Source: Passive (10202 - Absence of Anti-CSRF Tokens)
Input Vector:

Description:

No Anti-CSRF tokens were found in a HTML submission form.
A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF

Other Info:

No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "password" "username"].

Solution:

Other Info:

No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "password" "username"].

Solution:

Phase: Architecture and Design
Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid.
For example, use anti-CSRF packages such as the OWASP CSRFGuard.

Reference:

https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
https://cwe.mitre.org/data/definitions/352.html

Alert Tags:

Key	Value
OWASP_2021_A01	https://owasp.org/Top10/A01_2021-Broken_Access_Control/
POLICY_QA_STD	
POLICY_PENTEST	
SYSTEMIC	https://www.zaproxy.org/docs/desktop/addons/common-library/alerttags/#systemic
WSTG-v42-SESS-05	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_...

Spider AJAX Spider Active Scan Insights

Application Error Disclosure

URL: http://the-internet.herokuapp.com/upload
Risk: Low
Confidence: Medium
Parameter:
Attack:
Evidence: HTTP/1.1 500 Internal Server Error
CWE ID: 550
WASC ID: 13
Source: Passive (90022 - Application Error Disclosure)
Input Vector:

Description:

This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.

Other Info:

Other Info:

Solution:

Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.

Reference:

Alert Tags:

Key	Value
WSTG-v42-ERRH-02	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_...
WSTG-v42-ERRH-01	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_...
OWASP_2021_A05	https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
POLICY_QA_STD	
POLICY_PENTEST	

Current Status 0 0 0 0 0 0 0 0 0

der AJAX Spider Active Scan Insights

Authentication Request Identified

URL: http://the-internet.herokuapp.com/authenticate
Risk: Informational
Confidence: Low
Parameter: username
Attack:
Evidence: password
CWE ID:
WASC ID:
Source: Passive (10111 - Authentication Request Identified)
Input Vector:

Description:

The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.

Other Info:

userParam=username
userValue=ZAP
passwordParam=password

Solution:

der AJAX Spider Active Scan Insights

Other Info:

userParam=username
userValue=ZAP
passwordParam=password

Solution:

This is an informational alert rather than a vulnerability and so there is nothing to fix.

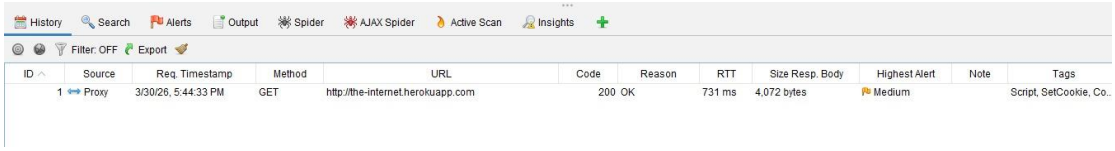
Reference:

https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

Alert Tags:

Key

- **History Tab Screenshot** → login/logout evidence



History Search Alerts Output Spider AJAX Spider Active Scan Insights

Filter: OFF Export

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
1	Proxy	3/30/26, 5:44:33 PM	GET	http://the-internet.herokuapp.com	200	OK	731 ms	4,072 bytes	Medium		Script, SetCookie, Co..

Observations :

- Spider successfully discovered all pages.
- Active Scan completed without errors.
- Mostly configuration issues detected (security headers, cookie flags).
- No major SQL Injection or XSS found (demo site).

Conclusion & Recommendations:

- Implement proper security headers and cookie flags for better protection.
- Automated scanning with ZAP is effective for detecting configuration and session-related vulnerabilities.
- Demo site is safe from high-risk vulnerabilities.

Github Repository :

https://github.com/dariyahashmi2602-source/SQA_Week-5-_security-testing-summary